

RESPUESTAS TÉCNICAS - EXPERTO GOBIERNO DE DATOS

CodeflowX - Análisis Gobierno Datos y GDPR Compliance

☐ RESUMEN EJECUTIVO

☐ RESPUESTA 1: DATA-IN-PERIMETER Y CONECTIVIDAD EXTERNA

☐ RESPUESTA 2: DPIA Y DATOS DE PRUEBA

☐ RESPUESTA 3: TRANSFERENCIAS INTERNACIONALES

☐ RESPUESTA 4: EJERCICIO DERECHOS GDPR (Art. 15-22)

☐ RESPUESTA 5: AUDIT PACK (Anexo IV)

☐ RESPUESTA 6: HITL Y STOP BUTTONS

☐ RESPUESTA 7: INSTRUCCIONES DE USO (Art. 13)

☐ RESPUESTA 8: EU DATABASE (Art. 71)

☐ RESPUESTA 9: POLÍTICAS GRANULARES VS GLOBALES

☐ GAPS Y TRANSPARENCIA

☐ ROADMAP CORTO PLAZO (Q1 2025)

☐ PRÓXIMOS PASOS

☐ CONTACTO

RESPUESTAS TÉCNICAS - EXPERTO GOBIERNO DE DATOS

CodeflowX - Análisis Gobierno Datos y GDPR Compliance

Fecha: Noviembre 2025

Para: Experto Gobierno de Datos

De: CodeflowX Team - Manuel González, CTO

☐ RESUMEN EJECUTIVO

Agradecemos las preguntas técnicas detalladas. A continuación respondemos con total transparencia sobre nuestra arquitectura de gobierno de datos, implementación GDPR y EU AI Act.

Enfoque: Respuestas honestas basadas en implementación real, reconociendo gaps donde existen.

☐ RESPUESTA 1: DATA-IN-PERIMETER Y CONECTIVIDAD EXTERNA

¿Cómo garantizamos data-in-perimeter?

Arquitectura self-hosted:

☐ **Componentes 100% on-premise (sin salida datos):** - Backend Spring Boot (Govern Platform) - PostgreSQL (base datos relacional) - Qdrant (base datos vectorial) - OpenSearch (logs y búsqueda) - Prometheus/Grafana (métricas) - RabbitMQ/Kafka (mensajería) - 20+ microservicios Python evaluación

Todos los datos sensibles (modelos, prompts, evaluaciones, logs, compliance) permanecen dentro del perímetro cliente.

Componentes que SÍ requieren conectividad externa (opcional):

△ **LLM Providers externos (si cliente los usa):** - OpenAI API (GPT-4, GPT-3.5) - Anthropic API (Claude 3.5) - Azure OpenAI - Google Vertex AI - AWS Bedrock

Flujo datos:

Cliente Self-Hosted → API Externa LLM → Respuesta → Cliente Self-Hosted
(solo prompts) (solo text)

Datos enviados: Solo prompts de evaluación (NO metadatos sensibles, NO datos compliance)

Datos recibidos: Solo respuestas texto modelo

Mitigación: - ☐ Cliente puede usar **modelos on-premise** (Llama, Mistral self-hosted) - ☐ **Proxy interno** opcional para LLMs externos - ☐ **Azure OpenAI en región UE** para clientes que requieren DPA Microsoft - ☐ Configuración granular: Cliente decide qué modelos usar

△ **Conectividad externa OPCIONAL (instalación/actualización):** - **Instaladores Docker:** Descarga imágenes desde registry CodeflowX (solo instalación inicial) - **Actualizaciones:** Pull imágenes nuevas versiones (planificado, no automático)

Solución air-gapped: - ☐ **Opción disponible:** Entrega imágenes Docker en USB/disco para ambientes desconectados - ☐ **Registro privado:** Cliente puede hospedar propio registry Docker interno

Garantía data-in-perimeter:

☐ **SÍ garantizado para:** - Datos compliance (FRIA, QMS, Risk Assessments) - Logs inmutables (Art. 19) - Metadatos modelos y proyectos - Evaluaciones y métricas - Datos entrenamiento y datasets

△ **Depende configuración cliente:** - Si usa LLMs externos → Prompts salen (controlado por cliente) - Si usa modelos on-premise → 100% data-in-perimeter

Recomendación sectores críticos (banca, salud, público): - Usar modelos on-premise (Llama, Mistral self-hosted) - O Azure OpenAI región UE con DPA Microsoft

☐ RESPUESTA 2: DPIA Y DATOS DE PRUEBA

¿Realizamos DPIA sobre datos procesados en evaluaciones?

Respuesta: ☒ **SÍ, implementado**

Implementación: DPIA integrada en proceso FRIA según Art. 27.4 AI Act

Art. 27.4 AI Act: *“La evaluación de impacto podrá integrarse en una evaluación de impacto relativa a la protección de datos contemplada en el artículo 35 del RGPD”*

Entidad: FriaAssessment (tabla FRIAFUNDAMENTALRIGHTSASSESSMENTS)

Campos DPIA incluidos: - Descripción tratamiento datos (Art. 35.7.a GDPR) - Evaluación necesidad y proporcionalidad (Art. 35.7.b) - Riesgos derechos y libertades (Art. 35.7.c) - Medidas mitigación (Art. 35.7.d) - Aprobación DPO si aplica (Art. 35.2)

Workflow: fria_assessment_process (cubre FRIA + DPIA integrado)

Campos DPIA: - Descripción tratamiento datos - Necesidad y proporcionalidad - Riesgos derechos y libertades - Medidas mitigación - Aprobación DPO (si aplica)

¿Qué datos prueba usamos y cómo pseudonimizamos?

Datasets públicos pre-configurados (NO datos reales): -

HumanEval (164 problemas Python) - Sin PII - MS MARCO (8,841 passage ranking) - Datos públicos - SQuAD (10,570 Q&A pairs) - Wikipedia pública - CNN/DailyMail (11,490 summarization) - News públicas - TriviaQA (87,622 trivia) - Sin PII - StereoSet (17,000 bias detection) - Datos sintéticos

Datasets cliente (datos reales):

☒ **Análisis PII automático (Microsoft Presidio):** - Detección automática: Email, teléfono, DNI, tarjetas crédito, direcciones - **50+ tipos PII** detectados - Score riesgo PII (LOW/MEDIUM/HIGH/CRITICAL)

☒ **Pseudonimización/Anonimización implementada:**

Técnicas disponibles: 1. **k-anonymity** (k=2,5,10 configurable) 2. **l-diversity** (diversidad atributos sensibles) 3. **t-closeness** (distribución preservada) 4. **Masking** (reemplazo tokens) 5. **Hashing** (SHA-256 irreversible) 6. **Generalization** (agregación valores)

Microservicio: leka-bias-detection-service

Endpoints: - /api/privacy/analyze - Análisis k-anonymity, l-diversity - /api/privacy/detect-pii - Detección PII con Presidio - /api/privacy/anonymize - Anonimización datos

Flujo evaluación con datos cliente:

1. Cliente carga dataset
2. Análisis PII automático (Presidio)
3. Si PII detected → Alerta usuario
4. Usuario decide: Anonimizar / Masking / Pseudonimizar
5. Evaluación sobre datos procesados
6. Resultados NO contienen PII original
7. Logs almacenan datos anonimizados

DPIA específica evaluaciones: - ☐ Análisis previo riesgo PII en dataset - ☐ Justificación necesidad datos específicos - ☐ Medidas técnicas (k-anonymity, masking) - ☐ Retención limitada (datasets eliminados post-evaluación) - ☐ Acceso restringido (RBAC)

☐ **RESPUESTA 3: TRANSFERENCIAS INTERNACIONALES**

¿Cómo gestionamos transferencias fuera EEE con OpenAI/Anthropic?

Respuesta honesta: **Depende configuración cliente y modelo DPA**

Escenarios:

A. Cliente usa modelos on-premise (Llama, Mistral):

☐ **NO hay transferencia internacional** - Datos permanecen 100% en infraestructura cliente (UE/EEE) - Compliance GDPR garantizado - **Recomendado para:** Sectores críticos (banca, salud, público)

B. Cliente usa OpenAI API (USA):

SÍ hay transferencia internacional → Requiere salvaguardas Art. 46 GDPR

Opciones implementadas:

Opción 1 - DPA OpenAI (Standard Contractual Clauses): - OpenAI tiene DPA basado en **SCC (Cláusulas Contractuales Tipo) aprobadas UE** - Cliente firma DPA OpenAI directamente - CodeflowX NO intermediario (cliente → OpenAI directo) - ☐ Válido GDPR si cliente acepta

Opción 2 - Azure OpenAI (región UE): - Microsoft Azure OpenAI deployed en **North Europe (Irlanda) o West Europe (Países Bajos)** - Datos procesados dentro UE/EEE - DPA Microsoft (SCCs aprobadas) - ☐ **Mejor opción** para clientes enterprise UE

C. Cliente usa Anthropic API (USA):

SÍ hay transferencia internacional - Similar OpenAI: DPA Anthropic con SCCs - Cliente firma DPA directamente

¿Implementamos cláusulas contractuales tipo?

Nuestra posición:

× **CodeflowX NO es “processor” de datos clientes con LLMs externos** - Cliente decide qué LLM usar (configuración) - Cliente firma DPA con proveedor LLM directamente - CodeflowX facilita configuración pero NO intermedia datos

☐ **CodeflowX Sí es “processor” para:** - Datos almacenados en PostgreSQL (compliance, logs, etc.) - Procesamiento interno evaluaciones - **Para esto:** Ofrecemos DPA CodeflowX con SCCs si cliente lo requiere

Documento disponible: - ☐ Data Processing Agreement CodeflowX (template SCCs aprobadas UE) - ☐ Anexo técnicas seguridad (ISO 27001) - ☐ Sub-procesadores listados

Tracking transferencias: - Campo: Data Processing → International Transfers (tabla DPRDATA PROCESSING) - Registro: Proveedor, país destino, salvaguarda aplicada (SCC, DPA, Adequacy Decision)

☐ RESPUESTA 4: EJERCICIO DERECHOS GDPR (Art. 15-22)

¿Cómo facilitamos ejercicio derechos sobre datos evaluaciones y logs?

Respuesta: ☐ **Implementado - Sistema automatizado**

Entidad: DataSubjectRequest (tabla DSRDATASUBJECTREQUESTS)

7 Derechos GDPR implementados:

Derecho GDPR	Artículo	Implementación CodeflowX	Estado
Acceso	Art. 15	Exportación datos interesado (JSON/PDF)	☐ 100%
Rectificación	Art. 16	Workflow corrección datos	☐ 100%
Supresión (Olvido)	Art. 17	Eliminación datos + logs (con excepciones legales)	☐ 95%
Limitación	Art. 18	Flag restricción procesamiento	☐ 85%
Portabilidad	Art. 20	Exportación JSON/XML/CSV	☐ 100%
Oposición	Art. 21	Workflow oposición tratamiento	☐ 90%
Explicación	Art. 22	Explicabilidad decisiones automatizadas (SHAP/LIME)	☐ 100%

Proceso ejercicio derecho:

1. Solicitud recibida (email/web/API): - ☐ Creación automática DataSubjectRequest - ☐ Campos: tipo derecho, identificación solicitante, fecha límite (30 días) - ☐ Workflow BPMN: data_subject_rights_workflow

2. Identificación datos interesado: - ☐ Búsqueda cross-table (evaluaciones, logs, compliance docs) - ☐ Identificadores: Email, UUID user, metadatos

3. Ejecución derecho:

Art. 15 (Acceso): - ☐ Reporte PDF/JSON con TODOS los datos: - Evaluaciones realizadas - Logs inmutables (anonimizados si terceros) - Metadatos proyectos - Datos compliance (FRIA, Risk Assessments) - ☐ Plazo: 30 días (automatizado recordatorio día 25)

Art. 17 (Supresión/Olvido): - ☐ Eliminación datos personales - ☐ Excepciones legales (Art. 17.3): - Logs inmutables Art. 19 AI Act (CONFLICTO normativo) - Datos compliance obligatorio conservar (Art. 18 AI Act: 10 años) - **Solución:** Pseudonimización irreversible (hashing) en vez de eliminación - ☐ Confirmación eliminación con certificado

Art. 20 (Portabilidad): - ☐ Exportación formatos: JSON, XML, CSV - ☐ Estructura legible máquina - ☐ Transferencia otro responsable (si solicitado)

Art. 22 (Explicación decisiones): - ☐ Explicabilidad modelo: SHAP, LIME - ☐ Human-friendly explanations (no técnico) - ☐ Factores influyeron decisión

Challenges específicos AI Act vs GDPR:

☐ CONFLICTO NORMATIVO:

Requisito	AI Act	GDPR	Solución CodeflowX
Retención logs	Art. 18: 10 años obligatorio	Art. 17: Derecho supresión	Pseudonimización irreversible (hashing UUID)
Immutable logs	Art. 19: No modificables	Art. 16: Rectificación	Logs inmutables + Nota rectificación anexa
Audit trail	Art. 12: Conservación evidencia	Art. 17: Olvido	Anonimización manteniendo estructura audit

Nuestra interpretación legal: - Art. 17.3.b GDPR: Excepción “cumplimiento obligación legal UE” → **AI Act prevalece** - Aplicamos **pseudonimización fuerte** (SHA-256 irreversible) en vez de eliminación - Mantenemos estructura logs (compliance) pero sin datos personales identificables

Nota: Interpretación validable con DPO cliente y/o autoridad protección datos.

☐ RESPUESTA 5: AUDIT PACK (Anexo IV)

¿Incluye TODOS los elementos requeridos Anexo IV?

Respuesta: ☐ **SÍ - 12 secciones Anexo IV completas**

Anexo IV - Documentación Técnica (Art. 11.1):

Sección Anexo IV	Requisito	Implementación CodeflowX	Estado
------------------	-----------	--------------------------	--------

1. Descripción general	Uso previsto, usuarios, nivel rendimiento	Template generator	☐ 100%
2. Descripción detallada elementos	Arquitectura, datos input/output	Auto-generado desde metadatos	☐ 100%
3. Seguimiento, interpretación outputs	Capacidades, limitaciones, thresholds	Documentación automática	☐ 100%
4. Especificaciones técnicas	Hardware, software, versiones	Auto-detectado sistema	☐ 100%
5. Descripción proceso desarrollo	Metodología, lifecycle, versioning	Git integration + tracking	☐ 95%
6. Validación y testing	Test results, métricas, benchmarks	100+ métricas automáticas	☐ 100%
7. EU Declaration Conformity	Referencia declaración (Anexo V)	Link automático	☐ 100%
8. Descripción gestión calidad	QMS implementado (Art. 17)	13 módulos QMS	☐ 100%
9. Gestión cambios y versiones	Change log, version control	Git commits + manual entries	☐ 95%
10. Human oversight	Medidas supervisión (Art. 14)	HITL workflows documented	☐ 100%
11. Ciberseguridad	Medidas protección (Art. 15.3-15.5)	Security controls documented	☐ 100%
12. Precisión, robustez, ciberseguridad	Métricas performance (Art. 15.1-15.2)	Automático desde evaluaciones	☐ 100%

Elementos específicos cubiertos:

Training Dataset (Anexo IV.6.a): - ☐ Descripción dataset (tamaño, fuente, características) - ☐ Metodología recolección - ☐ Criterios filtrado y limpieza - ☐ Análisis bias pre-training - ☐ **PII detection** (Presidio) sobre training data - ☐ Licencias y copyright (si aplicable)

Arquitectura Modelo (Anexo IV.2.b): - ☐ Tipo modelo (transformer, CNN, etc.) - ☐ Número parámetros - ☐ Capas y configuración - ☐ Fine-tuning aplicado (si aplica) - ☐ Adapters usados (LoRA tracking)

Métricas Performance (Anexo IV.6.b): - ☐ **Auto-generadas desde evaluaciones:** - Accuracy, Precision, Recall, F1 - BLEU, ROUGE (si LLM) - Toxicity, Bias scores - Adversarial robustness - ☐ Benchmarks

vs modelos referencia - ☐ Error rates y limitaciones conocidas

Gestión Riesgos (Anexo IV.8): - ☐ Risk Assessment completo (Art. 9)
- ☐ Riesgos identificados + severidad - ☐ Medidas mitigación implementadas - ☐ Residual risks documentados

Medidas Ciberseguridad (Anexo IV.11): - ☐ Adversarial testing results - ☐ Vulnerability scanning - ☐ Prompt injection detection - ☐ Data leakage prevention - ☐ Encryption (en reposo y tránsito) - ☐ Access control (RBAC)

Generación automática audit pack:

☐ **Endpoint:** POST /api/documentation/generate-technical-doc

Input: project_id

Output: PDF Anexo IV completo (50-100 páginas) con: - 12 secciones pobladas automáticamente - Gráficos métricas evaluación - Tablas risk assessment - Screenshots arquitectura - Logs auditoría anexos

Generación: Automatizada desde metadatos sistema. Exportación PDF disponible.

☐ RESPUESTA 6: HITL Y STOP BUTTONS

¿Implementamos HITL más allá de aprobación? ¿Hay stop buttons?

Respuesta: ☐ **SÍ - Múltiples niveles intervención**

Implementación HITL (Art. 14):

Nivel 1: Aprobación Workflows (Básico)

- ☐ Tareas BPMN requieren aprobación humana
- ☐ Ejemplos: Aprobar FRIA, Aprobar QMS, Aprobar deployment

Nivel 2: Human Oversight Decisions

- ☐ **Entidad:** HumanOversightLog (tabla HOLHUMANOVERSIGHTLOGS)
- ☐ **Triggers automáticos HITL:**
 - Risk score > 80 (alto riesgo)
 - Confidence < 70% (baja confianza modelo)
 - Grupos vulnerables afectados
 - Decisión impacto legal/económico
 - Drift detected (modelo degradado)

Flujo:

1. Decisión IA generada
2. Sistema evalúa triggers HITL
3. Si trigger → PAUSA decisión automática
4. Notificación human reviewer (email/Slack/UI)
5. UI presenta: Input, Predicción, Confianza, Explicación (SHAP)
6. Human decide: APPROVE / REJECT / REQUEST_INFO
7. Decisión registrada immutable log (Art. 19)

8. Proceso continúa con decisión final

Nivel 3: Stop Buttons / Intervención Tiempo Real

□ Implementado en múltiples capas:

A. Experiments/Training (UI ZKoss): - Botón “Stop Experiment” (stopExperiment() method) - Detiene entrenamiento inmediatamente - Estado → STOPPED - Checkpoint guardado - **Componente:** ExperimentsDetailViewModel.java

B. Notebooks/Execution (UI React): - Botón “Detener” (stopExecution() method) - Para ejecución células Jupyter - Kill procesos Python background - **Componente:** notebook-editor.tsx

C. Agent Monitoring (Microservicio Python): - **Capacidad:** Detención agentes en producción mediante API - **Implementación:** Workflows HITL + flags status agent - Estados: RUNNING → PAUSED → STOPPED → EMERGENCY_STOPPED - Notificación inmediata equipo - Logs inmutables razón parada (Art. 19) - **Microservicio:** leka-agent-monitoring

D. Model Inference (API): - Endpoint: POST /api/model/halt-inference - Detiene inferencias modelo específico - Circuit breaker activado - Requiere aprobación reinicio

Override capability (Art. 14.4.d):

□ **Implementado:** - Human reviewer puede **overridear** decisión IA - □ Justificación obligatoria (min. 50 chars) - □ Registro inmutable override (Art. 19) - □ Estadísticas: Override rate, HITL rate

Métricas tracking: - HITL interventions / total decisions - Override rate (%) - Tiempo promedio intervención humana - Razones override más frecuentes

□ RESPUESTA 7: INSTRUCCIONES DE USO (Art. 13)

¿Generamos automáticamente instrucciones de uso para alto riesgo?

Respuesta: □ **SÍ** - Auto-generación desde metadatos

Art. 13.3.b - Instrucciones de Uso (Instructions for Use):

Elementos obligatorios generados:

Requisito Art. 13.3.b	Auto-generado	Fuente
1. Identidad proveedor		Metadata proyecto
2. Uso previsto		Project.intendedUse
3. Nivel precisión		Evaluaciones automáticas
4. Robustez y		

ciberseguridad	Adversarial tests
5. Outputs esperados	Metadata modelo
6. Duración del sistema	Lifecycle tracking
7. Mantenimiento y actualizaciones	Version control
8. Medidas supervisión humana	HITL config documented
9. Limitaciones conocidas****	Auto-detectadas evaluaciones

¿Cómo documentamos limitaciones conocidas?

▢ **Detección automática limitaciones:**

Fuentes: 1. **Evaluaciones métricas:** - Si Accuracy < 95% → Limitación “precision moderada” - Si Bias score > 20% → Limitación “posible sesgo demográfico” - Si Hallucination rate > 10% → Limitación “puede generar información incorrecta” - Si Adversarial robustness < 70% → Limitación “vulnerable ataques adversarios”

2. **Análisis datos entrenamiento:**

- Gaps cobertura geográfica → Limitación “datos primariamente región X”
- Desbalanceo clases → Limitación “mejor performance clase Y”
- Temporal coverage → Limitación “datos hasta fecha X”

3. **Condiciones uso:**

- Input constraints → Limitación “requiere input formato X”
- Output constraints → Limitación “genera outputs limitados a Y tokens”
- Context window → Limitación “contexto máximo Z tokens”

Template generado:

```
## LIMITACIONES CONOCIDAS

### Precisión
- Accuracy general: 87.3% (evaluado con dataset XYZ)
- Performance degradada en: [categorías específicas]

### Bias Potencial
- Sesgo detectado atributo: [género/edad] (score: 23.4%)
- Recomendación: Supervisión humana decisiones grupo vulnerable

### Robustez
- Adversarial robustness: 72.1%
- Vulnerable a: [tipos ataques específicos]
- Mitigación: Input validation + HITL

### Datos Entrenamiento
- Cobertura geográfica: Primariamente Europa/Norte América
- Temporal: Datos hasta Octubre 2024
- Idiomas: Inglés (90%), Español (8%), otros (2%)
```

▢ **RESPUESTA 8: EU DATABASE (Art. 71)**

¿Preparamos información registro EU Database? ¿Qué campos exactos?

Respuesta: ☐ Sí - Entidad completa con 3 secciones Anexo VIII

Entidad: EuRegistration (tabla REGEUREGISTRATIONS)

Anexo VIII - 3 Secciones:

SECCIÓN A: Sistemas IA Alto Riesgo (Art. 49.1) - 13 campos:

Campo Anexo VIII	Obligatorio	CodeflowX Field	p
1. Nombre y tipo sistema IA		project.name, project.type	
2. Proveedor (nombre, dirección, contacto)		provider.name, provider.address	
3. Representante autorizado UE (si no-UE)	△	provider.authorizedRep	△
4. Responsable despliegue (datos contacto)	△	deployer.contactInfo	△
5. Categoría Anexo III		project.annexIIICategories	
6. Uso previsto		project.intendedUse	
7. Región geográfica uso		project.geographicScope	
8. Certificado conformity assessment		conformityAssessment.certificateId	
9. Link declaración UE conformidad		conformityDeclaration.url	
10. URL instrucciones de uso		instructionsForUse.url	
11. Número CE marking		ceMarking.number	
12. Link documentación técnica		technicalDoc.url	
13. Link resumen sistema		systemSummary.url	

SECCIÓN B: Sistemas Identificación Biométrica (Art. 49.2) - 9

campos:

- Similar a Sección A pero específicos biometría
- ☐ Implementados si annexIIICategory = "III.1"

SECCIÓN C: Infraestructuras Críticas (Art. 49.3) - 5 campos:

- Subset Sección A para infraestructuras críticas
 - ☐ Implementados si annexIIICategory = "III.2"
-

Estado integración:

☐ **Preparación datos: 100%** - Todos los campos Anexo VIII mapeados
- Auto-population desde entidades existentes - Validación completitud pre-submission

☐ **Integración API UE: Pendiente** - **Razón:** API EU Database no publicada aún por Comisión Europea - **Deadline publicación API:** Estimado Q2-Q3 2026 (antes deadline 2 ago 2026) - **Nuestra preparación:** - Entidad EuRegistration completa - JSON submission data preparado - Workflow BPMN eu_database_registration_process - **Conectaremos API en cuanto esté disponible**

Workaround temporal: - ☐ Exportación JSON/XML submission package - ☐ Cliente puede subir manualmente portal UE (cuando abra)
- ☐ Import response UE y almacenamiento regEuApiResponse

☐ RESPUESTA 9: POLÍTICAS GRANULARES VS GLOBALES

¿Las políticas son granulares por modelo/caso o globales?

Respuesta: ☐ Ambas - Sistema híbrido granular + global

Arquitectura políticas:

Nivel 1: Políticas Globales (Organización)

- **Entidad:** AIPolicy (tabla AIPPOLICYFRAMEWORK)
- **Scope:** Toda la organización
- **Contenido:**
 - Principios gobierno IA general
 - Compromiso compliance (ISO 42001 Clause 5.2)
 - Roles y responsabilidades
 - Aprobación top management
- **Frecuencia revisión:** Anual

Nivel 2: Políticas por Proyecto

- **Entidad:** Project (tabla PRJPROJECTS)
- **Scope:** Proyecto específico (puede incluir N modelos)
- **Contenido:**
 - Uso previsto específico

- Risk appetite específico
- Data handling policies
- Compliance requirements específicos (si sector regulado)

Nivel 3: Políticas por Modelo

- **Entidad:** Model (tabla MODMODELS)
- **Scope:** Modelo individual
- **Contenido:**
 - Acceptable use policy específica
 - Input/output constraints
 - Performance thresholds
 - Limitaciones conocidas
 - Grupos vulnerables afectados

Nivel 4: Políticas por Deployment

- **Entidad:** Deployment (tabla DEPDEPLOYMENTS)
- **Scope:** Deployment específico (modelo + ambiente)
- **Contenido:**
 - SLA específico
 - Human oversight requirements
 - Monitoring thresholds
 - Incident response específico

Ejemplo granularidad:

Proyecto: “Sistema RRHH Empresa X” - **Política global:** AI Policy corporativa CodeflowX - **Política proyecto:** Compliance Anexo III.4 (Employment) + GDPR sector RRHH - **Política modelo 1** (Filtrado CVs): - Threshold bias < 10% - HITL obligatorio si confidence < 80% - Explicación obligatoria todas decisiones - **Política modelo 2** (Chatbot onboarding): - Transparency disclosure Art. 52 - NO decisiones automatizadas - Logs 6 meses (no 10 años)

Herencia políticas:

Global → Proyecto → Modelo → Deployment
 ↓ ↓ ↓ ↓
 (Base) (Añade) (Refina) (Específica)

Override: Política más específica prevalece (deployment > modelo > proyecto > global)

❑ GAPS Y TRANSPARENCIA

Áreas con implementación parcial (honestidad):

Área	Estado	Gap
Transferencias internacionales	⚠ 85%	Tracking completo transferencias pero DPAs firmados por cliente (no

Derecho supresión (Art. 17)	⚠ 95%	CodeflowX) Conflicto AI Act Art. 18-19 (logs 10 años) - Solución: pseudonimización
EU Database API integration	📋 Pendiente	API no publicada por Comisión - Preparación datos 100%
DPIA templates multi-idioma	⚠ 90%	Solo ES/EN - Pendiente FR/DE/IT
Data lineage completo	⚠ 90%	Tracking modelos completo, datasets parcial

📅 ROADMAP CORTO PLAZO (Q1 2025)

Gaps planificados cerrar:

1. **Data lineage datasets:** 90% → 100% (2 semanas)
2. **DPIA multi-idioma:** 90% → 100% (1 semana)
3. **Derecho supresión enhancement:** Workflow DPO aprobación excepciones legales (2 semanas)
4. **Transferencias tracking:** Dashboard transferencias internacionales activas (1 semana)
5. **EU Database API:** Integración inmediata cuando API disponible (fecha TBD Comisión)

📅 PRÓXIMOS PASOS

Para profundizar:

1. **Demo técnica gobierno datos** (2 horas)
 - Arquitectura self-hosted detallada
 - DPIA + pseudonimización en vivo
 - Stop buttons y HITL workflows
 - Derechos GDPR automation
2. **Audit técnico** (1 día)
 - Revisión código fuente (bajo NDA)
 - Testing PII detection
 - Validación k-anonymity
 - Review logs inmutables
3. **Gap analysis específico** (medio día)
 - Requisitos específicos vuestros
 - Customizaciones necesarias
 - Timeline implementación

📅 CONTACTO

CodeflowX AI

Email técnico: tech@codeflowx.ai

Partnerships: partners@codeflowx.ai

Equipo Técnico:

Manuel González - CTO & Co-founder

manuel.gonzalez@codeflowx.ai

Quedamos a disposición para profundizar en cualquier aspecto técnico.

FIN DEL DOCUMENTO